

Custom Agent Boundaries

Fail the weak profile, tighten it, rerun the same test

Session 11 | 3 hours

Agenda

Segment	Time
What a profile controls	8 min
Current <code>.agent.md</code> structure	10 min
Weak profile and boundary violation	12 min
Least-privilege tools and paths	13 min
Stop, validation, and human handoff	9 min
Rerun and lab handoff	8 min

A profile is a role contract

Profile

role + tools + procedure + stop rules

Environment

actual permissions + repository access

Human

accept + revise + reject

The profile guides behavior. It does not grant authority.

Repository profile structure

```
.github/  
└─ agents/  
   └─ test-writer.agent.md
```

The file contains YAML frontmatter and a Markdown body. The filename identifies the profile across configuration levels.

Frontmatter used in the lab

```
---
name: Test-only writer
description: Adds focused JavaScript tests in tests/ and stops when production code must change.
target: github-copilot
tools:
  - read
  - search
  - edit
  - execute
disable-model-invocation: true
user-invocable: true
---
```

`description` is required. Omitting `tools` enables all available tools.

The weak profile looks convenient

```
tools: ["*"]
```

Add tests for the requested behavior.

Read the code, make any changes needed, run the tests, and report the result.

It never says which files may change or when to stop.

Use a hostile example

Add tests for updateOrderStatus.
Change tests only.

The implementation permits a reverse transition that the acceptance criteria reject.

The weak wording permits a source edit. One lucky run staying in scope does not fix the contract.

Make the failure repeatable

```
npm run check:weak
```

Expected failures include:

- every tool is enabled;
- no test-only path is named;
- no production-code stop exists;
- no verified command or human decision exists.

Tool allowlists are necessary

Need	Alias
Read source and tests	<code>read</code>
Find conventions	<code>search</code>
Edit test files	<code>edit</code>
Run the known test command	<code>execute</code>

But `edit` still needs a path rule in the body.

The body sets the path boundary

Allowed:

```
Read src/  
Search the repository  
Edit tests/  
Run npm test
```

Forbidden:

```
Edit src/  
Change manifests or workflows  
Add dependencies  
Push or merge
```

Stop instead of crossing the boundary

```
No files changed.  
Blocked: the requested assertion requires a production-code change under src/.  
Decision needed: approve a separate source change or revise the criteria.
```

The stop result is useful output. It names the conflict and the next human decision.

Rerun the same contract

```
npm run check:tight  
npm test
```

Expected:

```
PASS .../test-writer.agent.md  
tests 2  
pass 2  
fail 0
```

The weak profile fails. The tightened profile passes.

Pick the smallest extension

Need	Use
Repository - wide convention	Instructions
Repeatable procedure	Skill
Bounded specialist role	Custom agent
Approved external capability	MCP

Do not add MCP to a role that only needs repository files.

Lab handoff

1. Inspect the exact `.agent.md` structure.
2. Run the weak contract.
3. Record the permitted boundary violation.
4. Tighten tools, paths, validation, and stop behavior.
5. Rerun the contract.
6. Produce a no-change stop report.
7. Record human review.

The deliverable includes both the failed weak profile and the passing tightened profile.